RESPONSE TO REVIEWERS

Manuscript #Access-2026-49387

Revised title: *Two Reachability-Gated Relations in MST-wi: Temporal Mismatch, Oracle Admissibility, and Measurement Limits*

Qiulong Lin and Nanlei Chen

19 October 2026

Dear Associate Editor and Reviewers,

Thank you for the detailed reports. The revision is substantive rather than cosmetic, and we have kept the narrowing that both reports asked for: the title, the abstract, the running head and every claim are now restricted to the two reachability-gated relations that were actually examined. Three statements that were previously argued in prose are now computed from records and reproduced by script—the complete factorial design and its reconciliation, the truth table of the two relations, and a competitive differential baseline. The baseline is matched to ours at the level of the probe pair only: total request and information budgets differ (111 requests against the baselines' 84 shared probes), and the manuscript states the comparison in those terms rather than as an equal-budget contest. One experiment that had not been run at all (a competing differential baseline) has now been run and reported. Where a request could not be met with the evidence we have, we say so in the manuscript instead of softening the text; three of the twenty-one items are met only in part, and Section 4 of this letter lists them together with what is missing and why. One of the three (R1.9) is reported as an open scope question for the editor rather than as resolved.

References below are to the revised manuscript (31 pages, 26 tables). Table and section numbers are stable; page numbers are given for the tables most often at issue. Every number quoted in this letter was checked against the artefact that generates it—the macros in the analysis output and the raw JSON records they are computed from. This letter is prose, not a generated file, so the check is a separate step rather than an automatic consequence of compiling it; `check_letter_numbers.py` in the package re-runs that comparison.

1 Reviewer 1

1.1 Novelty positioning against existing BOLA testing research

Concern. The paper identifies limitations in reachability-based adjudication, oracle assumptions and metric design, but does not sufficiently distinguish these contributions from established work on oracle problems, stateful web testing, authorization testing and metamorphic testing. A structured comparison is requested.

Response. We agree that "a frozen snapshot goes stale" is not new, and the manuscript now says so explicitly. What we can support with evidence is narrower and is stated as three falsifiable increments rather than as a general positioning claim. (i) *Predicate level:* at source, the verdict of each of the two relations is a function of the crawl-time reachability model and the request outcome, so it is determined by quantities that a direct request-plus-oracle comparison already has (Section VII-B, confirmed by execution in Section VII-C). (ii) *Subset level:* the false proofs we exhibit are confined to the cells whose grant is invisible to the framework's own record, and the channel decomposition (Table 11, p. 14) shows exactly which channels those are; neither product's membership surface produces a single false *allow*. (iii) *Denominator level:* a pooled input-level specificity cannot resolve a failure confined to one class, and no fixed threshold can force such a class below it (Proposition 1 and Corollary 1, Section IV-E). We also state plainly that we do not compare detection rates and cannot, from our evidence, claim any.

Action. Section IX rewritten around these three increments; the claim of being "orthogonal" to prior work deleted; the abstract's first sentence and the conclusion restated in the same terms. To make the comparison traceable item by item, the following maps each element of the reviewer's list to what was already known and what this revision adds on the two relations examined:

Element	Already established	Added by this revision
Frozen crawl-time model goes stale	Mai et al. and MST-wi state the role-to-resource mapping is "not always available"; stale-crawl effects are folklore	A cell-level temporal control on two products: 29 stale false proofs, all repaired by same-credential recrawl, 0 under live reading (Table 12, p. 15)
Oracle problems in authorization testing	Established: no intrinsic oracle; differential probing lines use request-level oracles	A measured decomposition of one membership oracle's errors by channel (false denies only, named channels; Tables 11 and 15), and an admission rule for when an oracle shares a subsystem with enforcement (Section VI-E)
Direct request-level testers	BACScan-style probing and its predecessors are the established direct method	A differential-rule comparison on the same probe pair with the adjudication trade-off stated, not a detection contest (Table 20)
Metric dilution under pooled denominators	Simpson-type aggregation effects are classical	Proposition 1 and Corollary 1 instantiated for the follow-up-input specificity, with the class-share bound $[1-w,1]$ (Section IV-E)
Promotion of an MR failure to "proven violation"	Not previously separated in the MST-wi artifact	Source-level split of A (engine alarm), H (our promotion policy P) and T (independent truth) on the native run (Tables 24–26)

The claims this revision makes are confined to the last column, on the two reachability-gated relations and the fixed domains examined; the middle column is cited, not claimed.

1.2 A complete definition of the false-proof outcomes

Concern. The mapping between alarms, false alarms and proven violations and the ground-truth authorization state is not formalized consistently; decision variables and truth conditions are requested for every combination of request outcome, actual entitlement, oracle response and detector verdict, together with an account of how a legitimate successful request is distinguished from unauthorized access without letting the tested reachability model determine its own ground truth.

Response. Table 19 (Section VI-B, p. 20) is now that table. It defines the quantities over the 712 temporal cells: Y (the ordinary request succeeds), M (the crawl-time model lists the object for the subject), O (the introspection surface's answer, with an explicit "no definite answer" value), A (the alarm of either relation; on this domain both reduce to $y \wedge \neg m$) and D (the direct adjudicator, $y \wedge \neg o$), plus $H = A \wedge \neg o$, the promoted verdict of the state-calibrated method, which exists only where O is definite. The twelve rows cover every combination of (Y, M, O), and the count columns split each row by the ledger's entitlement E, so each row states its truth conditions for both values of E. On the anti-circularity point: the label E comes from the framework's own grant and membership ledger, which is an independent entitlement source; M is an *input* to the relations and is never used as a label. A legitimate success is separated from unauthorized access only by an independent *deny* from E together with a content-level *allow* observation—never by M—and the manuscript says that the relation's alarm is not evidence of illegal access.

Action. Table 19 and the definitions in Section IV-A; the three-way split of the native run into A (the engine's own alarm), H (our promotion policy) and T (confirmed) is given in Table 25 (p. 26). In this revision the failure and unknown contract is additionally consolidated in the body itself (Section III, "Unknown and failure handling"): how an E-undefined transaction, a Y-undefined execution error and an O-undefined surface are each classified, when the method abstains, which denominators exclude such cells, and how the exclusions are disclosed—fixed before the run by the pre-registered protocol, not negotiated per result. That section also discloses one protocol-to-implementation divergence rather than reconciling it silently: the protocol promised E=unknown for a modelled object with no recorded granting channel, while the implementation returns a genuine *deny* there. The revision now registers the closed-world default-deny reading as the rule the implementation adopts, reconciles the two calibers in a dedicated sensitivity table (Table 13): the reading changes the scorable set from 712 to the 171 cells whose ledger entitlement is E-allow under the literal rule, while the 29 stale false proofs and the 0 live false proofs fall on E-allow cells and are identical under both calibers; "no effect" is therefore claimed only for the false-proof phenomenon, not for the scoring denominators.

1.3 Characterization of authorization-state transitions

Concern. The three-phase protocol does not comprehensively model revocation, inherited permissions, public visibility, role changes and concurrent updates; the state-transition semantics, the timing of each observation and the consistency assumptions behind the deterministic false proofs are requested, as is whether the conclusions hold when authorization changes between request and adjudication.

Response. Section V-A now states the semantics that the experiment actually exercises, and three scope limits are stated as part of the result rather than buried in the discussion. The eight committed transitions are a designed set, and we list them by the name the run record uses rather than by category: direct grant, direct revoke, team-to-repository attach, team-member removal, private-to-public visibility, public-to-private visibility, a read-to-write role change, and a site-administrator grant. GitLab's set is the same shape with two of its own: group share and group-member removal. There is no team-detach, no member addition and no site-administrator revoke in the record; the two visibility directions are separate events. Each cell is serialised, no mutation is issued between a cell's request and its probe, so the window between them is static *by construction*; and a deployment in which a grant or revoke lands inside that window is outside what these cells measure—for such a case the cell's conclusion does not apply and the observation must be repeated, which the manuscript says we do not claim to detect. Revocations behave differently from grants, and the manuscript is explicit that they must not be scored as misses: the stale model still lists 17 cells whose access was revoked (7 on Gitea, 10 on GitLab), and in every one of them the request is refused, so no violation occurred and nothing was missed—scoring them as false negatives would require $E =$ deny and $Y =$ allow together, which never happens here (Table 12, p. 15). On concurrency, the harness is single-threaded, no concurrent writer ran, and *hv* is declared to be a harness-maintained logical version rather than an atomic server snapshot—which is what makes the still window meaningful.

Action. Section V-A (Table 12, p. 15); the same scope limits restated in Section VIII.

1.4 Operationalizing the admissibility condition

Concern. Clause (2)—that the oracle is not affected by the same defect under investigation—remains a qualitative judgement; a reproducible procedure for determining admissibility *before* examining outcomes is requested.

Response. We agree this is the weakest link, and we have now fixed the procedure rather than only describing it. Clause (2) is operationalised as a standalone admission protocol—defect classes fixed in advance, four evidence levels, an ordered *admit*/*reject*/*unknown* decision rule, the claim each status licenses, falsifiers and change control—frozen with its digest before the multi-class and matched-budget experiments reported in Sections V-D and VI-D, and applied both to those experiments and conservatively to the archived ones (Section VI-E). Its epistemic status is stated plainly: it was not part of the original submission and we do not backdate it; the pre-registered protocol pinned by digest recorded the qualitative judgement (`oracle_independence=shared`; the oracle read for diagnosis only) but did not contain the procedure. What the protocol changes is the timing the reviewer asked about: the rule now exists before the results it judges, and the register records which level each verdict rests on. The rule itself: at evidence level L1, identify by probing which endpoints answer *y* and *o* and infer the processes and permission models behind them; at L2, read the pinned source and locate the decision point on each path; at L3, intervene and observe whether a defect propagates across the two paths. *Admit* only on L2 non-sharing or L3 non-propagation; *reject* if the paths share a decision point or a component whose failure could co-occur with the tested defect, or if at L1 both are answered by one process applying one permission model; *unknown* if either path cannot be enumerated, which also refuses promotion. Applied thus: on Gitea the permission route the oracle consults and the content routes are answered by the same server binary applying the same permission model; on Gogs the per-object route enumerates direct collaborators only and the permission suffix that would expose the remaining channels does not exist (404); on GitLab the `members/all` route and the content routes are answered by the same application consulting the same membership tables. On those three products the enumeration stops at the server boundary, so the recorded status is *reject* at L1, not a claim of proven sharing. On the controlled target we can read the source, so the finer verdict is available and is also *reject*: the content decision calls the same function the oracle answers from, which makes the sharing visible at L2 instead of inferred at L1. That last decision has teeth in this revision: because the target's oracle is not admissible, the 9 per-class hits of Table 17 are reported as recall against known truth and explicitly not as independence-certified proofs. Three epistemic statuses are kept apart throughout: the diagnostic *O*/*H* readings; the gate-correctness classification against the independent ledger and content observation, which needs no oracle independence; and independence-certified proofs of previously unknown defects, which the rule refuses here. No recorded number changes under the rule.

Action. Section VI-E (the rule, the per-product path evidence, and the three epistemic statuses); `experiments/real_system/prereg/`

in the package holds the frozen protocol with its `SHA256SUMS` and the per-system application register, including the leave-one-out checks on the controlled target.

What remains. The evidence base for the three production products is API-observable behaviour, not an internal-source audit; a finer-grained per-component enumeration would be needed before any of them could be recorded as anything other than *reject*, and we did not perform that audit. The rule therefore refuses independence-based promotion on those products, which is why none of the real-system results is presented as a confirmed violation. This is stated as a limitation in Section VIII.

1.5 Proposition 2: separating the definitional from the empirical

Concern. The proposition risks being tautological; the formal identity should be distinguished from the empirical premise that the evaluated relations consume no additional decision-relevant information, with a truth-table derivation or explicit functional representation.

Response. The result is now split in two. **Lemma 1** (absorption) is the algebraic part: if a verdict is a function of an oracle answer and an ordinary request, it cannot outperform the direct consumer of those same inputs. That part is definitional and is labelled as such. **Proposition 2** is the empirical part, and it is deliberately narrower than the lemma's domain: premise (i) of the lemma—that the alarm reads only the crawl-time model and the response—holds for these two relations by source inspection, and on the domain studied both alarms reduce to $y \wedge \neg m$ against $D = y \wedge \neg o$. What is verified empirically is that predicate reduction. What holds algebraically is $A = D$ if and only if $y = 0$ or $m = o$, together with $H \Rightarrow D$. Premise (ii) of the lemma—that the model is O-determined on the domain—is *not* claimed: it does not hold on the recorded domain—rows 7 and 8 of Table 19 share $O =$ allow but differ in M, so O does not determine M there—and the manuscript says so rather than presenting the relation as informationally redundant in general. The explicit predicates are written out ($A_{002} = \neg sup(B,A) \wedge \neg m \wedge \neg err(o_1) \wedge q(o_1,o_2)$ and $A_{004} = y \wedge \neg m$, against $D = y \wedge \neg o$), and on the domain studied both reduce to $y \wedge \neg m$. The reduction was verified mechanically against 576 constructed records and 712 temporal cells with zero mismatches; the generating script exits rather than emitting the table if any record disagrees. The equivalence is stated correctly as $A = D \Leftrightarrow y = 0 \vee m = o$: where D is defined the two verdicts coincide in 530 of the 584 readable cells and part in the two rows with Y=allow and $M \neq O$—40 cells where the model is right and the oracle wrong, and 14 where the model is stale and the oracle right. Those two rows are the two failure mechanisms the cross-vendor section keeps apart. The falsification condition is stated: produce an observable, outside what a succeeding request plus a readable oracle can determine, on which an authorization metamorphic relation still decides.

Action. Section VI-B with Lemma 1, Proposition 2, Table 19 (p. 20) and the corrected equivalence; the earlier claim of extensional equality is deleted.

1.6 Coverage and identifiability of the 576-record enumeration

Concern. A transparent mapping from configurations and scenarios to all records is requested, with the complete factorial design, an account of how each factor is varied, attribution of the reported effects, and an explicit reconciliation of the 36/18 representative grid with the later 312/264 partition.

Response. The enumeration is now inspectable end to end. Table 1 (p. 5) is the complete design: seven factors, their levels, how each level is varied, the record count per level and what it crosses with, with the additive identity $44 \cdot 2 \cdot 3 \cdot 2 + 8 \cdot 3 \cdot 2 = 576$ in the footnote. Table 23 (p. 25) is the configuration-by-scenario census, where a dash marks an inadmissible combination and the caption says why (a configuration with no share has nothing to list; the listed-and-unreadable combination was not run, so it is untested rather than impossible). The reconciliation the reviewer asks for is Table 5 (p. 10): it starts from the S3–S7 original grid of 54 records (which contains 8 v2 false proofs) and adds the remaining blocks, asserting by record key that the blocks are mutually disjoint and that their union is exactly 576, split 312 readable / 264 unreadable. Section III-A states what the design can and cannot identify: the three dimensions are nested rather than crossed (the relation is single-valued on S5; channel and visibility are defined only inside one exception setting), so a full interaction estimate is not available—which is why attribution is done with matched pairs (Table 2, p. 5) rather than with a regression.

Action. Tables 1, 2, 5 and 23; Section III-A.

1.7 Comparison against competitive black-box methods

Concern. `direct_only` is deliberately unfair and `obs_success` and `always_alarm` are intentionally weak; a differential, multi-account authorization tester probing equivalent objects under distinct privilege levels is requested, with matched query budgets, execution costs and detection outcomes.

Response. This is the comment that required new experiments, and two have been run. *(i) Probe-pair comparison.* Section VI-D and Table 20 (p. 23) report three conventional differential rules on the same 42 controlled cells (six configurations crossed with S1–S7) and, critically, on the *same probe pair*: every method consumes one request as the owner and one as the actor—84 shared probes in all—and ours issues one additional read of the authorization surface on the 27 cells where a relation alarms and none where it does not (0.64 per cell on average, 27 reads in total). In that table the budget is matched at the level of the probe pair and only there: ours issues 111 requests against the baselines' 84, and it is the only method that reads the target's authorization surface, so total request count and visible information differ. *B1 status-only* alarms whenever the replayed request returns a non-error. *B2 equality replay* alarms only when the owner succeeded and the actor received byte-identical output—the differential rule with no authorization model. *B3* adds the strongest information a tester can hold without reading the target: it suppresses every cell covered by the tester's own share log. On these cells B1 and B2 claim on all 27 allowed cells with 12 false proofs each (precision 55.56%), B3 claims 21 with 6 false proofs (71.43%), all six on the out-of-band channel, and ours claims 10 with no false proof but 17 abstentions (coverage 59.52%). Recall is reported in the table under both denominators, because the two differ exactly where ours abstains: on the cells ours rules on, recall is 100%; over all 15 violation cells, including the 5 it abstains on, total recall is 66.67%. The baselines abstain on nothing, so both of their figures are 100%. Two readings are explicitly ruled out in the text: this is *not* a detection gain, because the baselines find all fifteen violations while ours confirms the ten whose surface is readable and declines the other five; and it is *not* a free improvement, because coverage falls to 59.52%. A corroborating observation on a real system is reported with the same qualification: on the Gitea snapshot the equality rule fires on all 25 legitimately allowed cells and the in-band log still leaves 24, because the framework log does not observe 0.96 of the effective access there—a property of the constructed topology, not an estimate of field prevalence. *(ii) Matched total budget.* Table 21 (p. 23) re-runs the same comparison under a total-request ceiling per cell instead of a probe-pair match, on the same 42 cells and with the same accounts and credentials. At a ceiling of two, only the owner/actor pair fits, and ours abstains on all 42 cells: a method that must read the authorization surface cannot claim anything when the budget does not reach it. At a ceiling of three, each method may spend one further observation of its own choosing, declared before the run—ours reads the authorization surface, a strengthened baseline B3r enumerates the actor's visible objects—and B1–B3 spend nothing extra, reported as under-spend rather than padded. Under that ceiling ours does not dominate: B3r reaches 14 of the 15 violations with 4 false proofs, ours 10 with none and 17 abstentions, and ours spends 111 of the 42×3 requests the ceiling allows because an abstaining cell costs nothing. No method receives a request it cannot use.

Action. Section VI-D, Table 20 (p. 23) for the probe-pair comparison and Table 21 (p. 23) for the matched-budget one; both runners (`experiments/run_baseline.py`, default and `-budget`) and their raw outputs are in the reproducibility package, and the generated tables are reproduced byte-identically by `verify_artifact.sh repro`.

What remains. No per-method wall-clock time. The complete comparison—both probes per cell and the additional reads included—ran in 22.5 s of wall-clock harness time covering setup, probing, scoring and cleanup, and that figure is recorded in the run output shipped with the artefact. The runner binds no CPU and measures no per-method CPU time, so we make no claim about single-core cost. We do not report a time per method because all four are scored from the same two recorded responses in the same process, so any per-method number would measure our replay loop rather than the rule. What the reviewer's question needs beyond that—the cost of the same probes against a live target—is reported for the real-system temporal loops only (Gitea 21.2 s, GitLab 7.3 s, of which the probes are 20.7 s and 6.0 s), where the requests really do reach a server. Beyond the wall-clock point, the budget condition of the request is now met twice over: at the probe-pair level (Table 20) and at a matched total-request ceiling (Table 21), the latter with the same credentials and a declared allocation of the one extra observation each method is allowed. What is not claimed is a detection advantage at that ceiling—the strengthened baseline reaches more violations than ours—nor a continuous budget curve: two ceilings are run, not a swept curve, because the decision the comparison turns on is whether the surface can be read at all, and that is a step, not a slope.

1.8 Channel-by-channel isolation of the oracle-validity problem

Concern. A channel-by-channel confusion matrix separating direct membership, team-derived access, administrative grants, public visibility and out-of-band sharing is requested, together with a distinction between an incorrect oracle response and a stale reachability model.

Response. Table 11 (Section V-A, p. 14) is that matrix: the owner-vantage introspection surface scored against the ledger per channel and per product, with cells, agreements in each direction, the two error directions, and a separate "unanswered" column for anonymous readers. Neither product produces a single false *allow*: the membership surface

errs only by omission, and public and site-administrator cells are exactly the channels that are not group or repository membership. The two failure mechanisms are kept apart by construction and by table: in the truth table, row 6 is the oracle answering *deny* on a cell the ledger allows (40 cells, an unsound oracle), row 7 is the model failing to list a cell the ledger allows (14 cells, a stale model), and the two verdicts disagree in precisely those rows. Gogs now carries the same channel decomposition (Table 15, Section V-B, p. 16), and the reason an earlier draft declared the gap instead is recorded in the manuscript, because it was a category error rather than a data limitation: a channel label is a property of the entitlement ledger—built from the lab topology, the documented inheritance rules and the recorded out-of-band grant events, and never from a probe response—so a product whose API exposes no per-object membership route does not lose the channel axis. What such a product loses is the ability to *enumerate* those grants through that route, which is a claim about the oracle surface, not about the labelling. On the same 48 snapshot cells the surface is correct on every cell it can represent—all 4 direct-collaborator cells and all 27 cells with no recorded grant—and answers *deny* on all 17 cells whose entitlement arises from team membership (4), public visibility (5) or site administration (8), with no false *allow* anywhere (0). Panel (b) of the same table re-groups the cells by mechanism, so out-of-band sharing is reported as a source axis rather than as a channel mutually exclusive with team or public; 1 cell carries two ledger rules and is counted once, under the stronger. That the blind spot belongs to the chosen surface rather than to the product's whole API is recorded rather than inferred: in the surface probe shipped with the run the per-object permission suffix returns 404, the per-object team route 404 and the collaboration route the oracle consults 204, while the organisation team listing is reachable (200). The decomposition is stable across readings (31 agreements and 17 false denials under the live reading), so the concentration is not an artifact of the snapshot.

Action. Tables 11, 13, 14 and 15; Sections V-A and V-B; the mechanism separation is Table 19 (Section VI-B).

What remains. The three affected strata on Gogs are small (4, 5 and 8 cells), so the per-channel rates describe this topology rather than estimate field prevalence; and the mechanism labels are the ledger's own rule text—the harness's record of how each grant was made—not a second, independent audit of the product's grant machinery.

1.9 Detection results across independently implemented defects

Concern. The three seeded instances share one fault pattern; the positive control should be expanded to multiple independently implemented authorization defects, including unauthorized reads, unauthorized modifications, inherited-permission errors and privilege escalation, with per-defect recall and false-positive rates.

Response. This is now implemented, and the result is not the one a recall-oriented reader would hope for, so we report it in full. Four defect classes are seeded on the controlled target, each independently switchable, and driven through the same crawl, introspection and adjudication code: C1 the read bypass already used (three instances), C2 a write bypass in which a subject whose true permission is `none` changes the object's metadata and the change is observable afterwards (two), C3 a faulty inheritance expansion in which an organization member outside the team is served the team's repository and—the point of the class—the defect lives in the expansion itself, so listing, search and object read agree (two), and C4 an escalation in which a subject that is neither owner nor administrator grants a third party access it should not have, the grant being recorded but marked as obtained through the defect so the correct model still answers `none` (two). Table 17 (p. 18) reports per-class recall against the seeded truth. The studied reachability-gated relation covers C1 and nothing else: 3 of 9 instances. C2 is invisible to it because the relation is defined on whether the object is *served*, not on whether it can be *changed*; moving the same relation to the channel the defect breaks recovers both instances, which is a property of the relation family, not of the relation we studied. C3 and C4 are worse than missed—in both the subject already sees the object, so `cannotReachThroughGUI` is false and the antecedent of the relation does not hold. The gate is not failing to notice them; it reads its own premise and concludes there is nothing to test. The oracle-consuming adjudicator fires on all 9 instances once the probe is channel-matched and on 7 of 9 when confined to the read channel. False alarms on the 23 authorized cells are 8 for the relation's bookkeeping variant and none for the oracle-based adjudicator, the latter conditional on this target's oracle being sound. Two limits are stated with the numbers: the target's oracle shares its decision function with the content path, so under the admission rule of Section VI-E every class is refused promotion and the 9 hits are recall against known truth rather than independence-certified proofs; and these are four mechanisms on one emulator, not four discoveries in production systems. Each class is also leave-one-out checked: disabling it removes its own alarms and leaves every other class's alarms in place, so an alarm is attributable to its defect rather than to a shared root cause. The publicly fixed CVE pair is retained alongside this, as a control of the gate rather than of recall: Section V-C and Table 18 (p. 18), one true positive on 1.20.5 and no claim on 1.20.6, with the seven-perturbation regression test unchanged.

Action. Section V-D and Table 17 (p. 18) for the four classes; Section V-C and Table 16 (p. 16) for the original seeded

control; Section V-E and Table 18 (p. 18) for the CVE pair; `experiments/real_system/run_multiclass.py` and `seeded_multiclass.json` in the package, regenerated byte-identically by `verify_artifact.sh repro`.

What remains. What the study does not establish. It is one emulator, so the per-class numbers measure whether the chain fires on known defects, not how often such defects occur; the classes were fixed before the runs, in the admission protocol shipped with the package, and we did not add a class after seeing which ones the gate caught. We also did not tune the gate for C3 or C4: making the antecedent true there would mean abandoning the reachability premise, which is the object of study rather than a parameter of it.

1.10 Control of temporal and observational effects

Concern. The ordering of crawling, entitlement mutation, oracle querying and request execution must be specified, with timestamps or event logs sufficient to verify that the comparison changes only the model-reading time, and an account of how live-state queries avoid changing the tested state or gaining privileges.

Response. The ordering is fixed and stated: crawl, then freeze the model at t_0, then commit the transition, then query the oracle, then issue the request; the enumeration, oracle and read probes are all `GET` requests; the write-capable transitions additionally carry one write probe (an HTTP POST creating the probe artifact) and an owner-side DELETE that restores the state, both recorded like every other call and neither changing any authorization configuration, so "nothing in the measurement path mutates state" holds for the authorization state the measurement is about, not for every HTTP method issued; the recrawl uses the same credential as the original crawl, so it grants no privilege the detector did not have; and the owner oracle is reported separately from the subject-side reading rather than pooled with it. The run record carries the protocol digest, the event sequence numbers, the policy version, the M_0/M_1 model digests and the per-request timestamps, and the harness version hv is declared to be a logical version rather than an atomic server snapshot. The results are symmetric across the two products: Gitea 280 cells with 13 stale false proofs, all 13 repaired by a recrawl with the same credential and 0 mismatches under the live reading; GitLab CE 432 cells with 16 stale false proofs, all 16 repaired and 0 under live reading.

Action. Section V-A and Table 12 (p. 15); the pre-registered protocol file, the run records and the amendment timing note are in the reproducibility package.

1.11 The specificity denominator

Concern. The 84.62% figure assumes two follow-up inputs per case and cannot establish the numerical behaviour of the published 99.81% figure; the original counts or a parameterized sensitivity analysis are requested, with a clear distinction from conventional specificity.

Response. The published figure is now treated as what it is: a specificity, $\mathrm{TN}/(\mathrm{TN}+\mathrm{FP})$, over the follow-up inputs F, with the manual verification of the reported failures acknowledged—so the labels are not the crawler's own answer, and we do not attribute the number to a circular label. The 84.62% illustration has been removed from the manuscript entirely, together with the claim that it agrees with the crawler. We cannot recover the engine's exact input count, so instead of substituting a value we parameterize: with $\mathrm{FN}=0$ the figure equals $1-\mathrm{FP}/(F-\mathrm{TP})$, a class supplying a share w of the negative inputs can move it only within $[1-w,1]$, and no fixed threshold $t<1$ can guarantee that a class-uniform failure pushes it below t (Proposition 1 and Corollary 1, Section IV-E). The proposed scenario-level quantity is labelled an analytical construct for characterising resolution, not a replacement metric, and the text says the finding is about what the published figure can be asked to show, not about its arithmetic.

Action. Section IV-E; restated in Section VI-C; the figure removed from the body.

1.12 Heterogeneous scenario weights

Concern. Proposition 1 assumes equal contributions per scenario; the result should be extended to unequal request counts, correlated inputs and different alarm counts per scenario, including the case where the number of generated inputs depends on scenario complexity or detector behaviour.

Response. The fixed-weight case is derived (Proposition 1 and its corollary, Section IV-E) and the arbitrary-share case is bounded without any equal-weight assumption: whatever the class shares are, a failing class contributing a share w of the negative inputs moves the figure only within $[1-w,1]$ (Section VI-C). Our records are a fixed enumeration in which the input count does not respond to the detector, so the endogenous case is not instantiated by any experiment here; what this revision adds is a conditional derivation of what an endogenous count can certify, stated below. Rather than assert a generality we cannot support, Section VIII states the limitation: records within a design cell are not independent, the records are a fixed enumeration, and we therefore report counts and rates rather than inferential

intervals, with no result resting on statistical significance. In this revision we additionally give the endogenous count its own conditional treatment (Section VI, "What an endogenous count certifies, conditionally"): for a method D and run ω with $n_i(D,\omega)$ negative inputs and $f_i(D,\omega)$ false proofs per scenario, the score $S = 1 - \sum_i f_i / \sum_i n_i$ is a counting identity per fixed run; for a family of runs, $S_k \to 1$ if and only if $\sum_i f_i / \sum_i n_i \to 0$ with the denominator positive. Two arithmetic examples bound the interpretation: a fixed number of false proofs under a growing input total gives $S_k = 1 - 1/k \to 1$ (the failure persists, only its weight vanishes), while false proofs growing as αk give $S_k = 1 - \alpha$ at every k (no dilution toward 1). The derivation is conditional on the run's scenario coverage—an unexercised failing class contributes nothing to either sum—and we do not use it as a detection guarantee.

Action. Section IV-E and Section VI-C; the limitation stated in Section VIII.

What remains. The endogenous derivation is per-run arithmetic plus an asymptotic condition; it assumes no model of detector-dependent generation, and the correlation of records still limits the statistical reading, as Section VIII states.

1.13 Consistent treatment of abstentions and operational cost

Concern. Perfect precision bought by abstention is not characterized by precision and recall alone; coverage, selective risk, abstention rate and performance conditional on oracle availability are requested, alongside execution time and request overhead, with a distinction between a safe abstention and a successful detection.

Response. Table 4 (Section IV-D, p. 9) rescored the same 576 records on the *decision* rather than on the alarm, and reports coverage, the abstention count and rate split by whether the record held a true violation, false proofs, misses and selective risk, with the explicit warning that risk is comparable across methods only at equal coverage—which these methods do not have. The state-calibrated method covers 60.42% and abstains 228 times; panel (b) splits those abstentions by reason, and only the first row (156 surface-unreadable, 108 of them true violations) is the availability gate the method is named for, the other 72 being a false proof converted into a non-decision. The direct methods abstain under the same unreadable-means-abstain contract (coverage 54.17%, 264 abstentions), and the forced-negative reference—coverage 100%, 108 misses, risk 18.75%—is labelled as the price of forcing a verdict on unreadable cells, not as a property of any method. A passed record is defined as one on which the method did not fire, explicitly not a certificate of safety, and the text refuses to rank by risk alone, noting that the always-degrade reference has the second-lowest risk while detecting nothing. Cost is reported as request counts: 4833 enumeration requests (median 8, range 7–10) and 104 probe `GET`s (52 cells $\times$ 2).

Action. Table 4 (p. 9) and Section IV-D; the abstention semantics unified across methods in Section IV-A.

What remains. Wall-clock execution time for the replay-based methods, for the reason given under comment 7.

1.14 Reproducibility of the principal claims

Concern. A version-pinned environment, exact commands, complete configuration and seed files, machine-readable raw outputs and scripts that regenerate every table and figure are requested, together with documentation of the two failed relation executions, the engine-side defect and the treatment of missing or failed observations.

Response. The package now carries a pinned environment, the exact commands, the seed and configuration files, the machine-readable raw records and the scripts that regenerate every table and figure, and it was verified rather than asserted: in a staging copy of the committed tree—extracted with `git archive`, so it cannot see the working tree—the pipeline regenerates all 31 byte-reproducible outputs byte-identically, including the two baseline tables; and in an empty directory the 93-file submission package compiles (31 pages, no undefined references). The native run is reported as three stages rather than one number (Section VII-C, Tables 24–26, pp. 25–27): A, the engine's own `getFailures()` alarms, 6; H, our promotion policy applied to them, 6; T, confirmed, 0—with 6 false proofs. The content predicate is reported by invocation count rather than claimed clean, and the text says so. The source-state facts of that run (upstream modification counts, the upstream commit) are generated from frozen inputs—the recorded upstream version, its content digest and the patch manifest archived with the run—rather than from a live checkout of the upstream workspace, so the outputs are a function of archived records alone; the live `git status` remains available only as an additional diagnostic and never feeds a reported number. The regeneration is same-host: it runs from the archived records on the same machine as the original experiments, against the pinned external MST source dependency, and it is not an independent rerun of the live experiments. The pipeline validates input hashes at entry, so an unverified or modified input fails the run before any table is produced, and the two artefact layers are documented separately: the 93-file LaTeX package compiles; the full repository reproduces the numbers. On the reviewer's phrase "two failed relation executions": the current record has one execution error, not two. Of the 11 catalog authorization relations evaluated against Gitea, 10 ran and 1 aborted on an engine-side defect; the number two is the count of

relations that alarmed (2 relations, 6 alarms in all, OTG_AUTHZ_002, OTG_AUTHZ_002c). The aborted relation, the engine-side defect and the alarm split are each documented at source, and the treatment of missing or failed observations is written into the protocol file that the run record binds.

Action. Section VII-C and Tables 24–26; `reproduce.sh`, `verify_artifact.sh` and the hash manifests in the package.

What remains. The failure and missing-observation rules were, at resubmission time, written in the protocol file and the scripts; this revision additionally consolidates them in the body itself (Section III, "Unknown and failure handling"), stated as implemented, including the transport-retry versus transaction-refusal distinction and the separate accounting of unanswered-oracle cells.

1.15 Narrowing the conclusions; an evidence-to-claim table

Concern. Statements suggesting that adjudication of genuine violations is absent from the evaluated relations risk extending beyond the experiments; conclusions established by source-level dependence, by the synthetic construction and on real systems should be distinguished, with a final table linking each research question to its assumptions, tested configurations, results and limitations.

Response. Table 22 (Section VI-E, p. 25) is that table. Each row names the assumption the claim needs, the artefact that carries it, and the boundary that remains; the last row is the adjudication gate and is marked as not being evidence about detection effectiveness. The three findings are explicitly attributed to different kinds of evidence—source-level functional dependence, a constructed enumeration, and two real-system studies—and the text says a reader should be able to see which kind carries which sentence. The sentence that extended beyond the experiments has been deleted, together with the mis-attribution of a constructed result to a published one; the title, abstract, running head and conclusion are narrowed to the two reachability-gated relations, and each finding is stated with its own falsification condition.

Action. Table 22 (p. 25); Section VI-E; title, abstract and Section X.

2 Reviewer 2

2.1 Novelty, and whether re-crawling or live reading removes the problem

Concern. State what is new beyond showing that a snapshot goes stale, and whether re-crawling or live reading removes the problem; the data show 0 mismatches under live reading on Gitea.

Response. Live reading removes the measured false proofs on both products: 0 mismatches under the live reading against 13 stale false proofs on Gitea and 16 on GitLab, and a recrawl with the same credential repairs 29 of 29. We removed the unconditional claim that more crawling is ineffective, and the text now says when a recrawl suffices—when the model can be refreshed with the same credential before adjudication—and when it does not: a grant the surface cannot enumerate at all is invisible to any recrawl, which is the out-of-band channel where the residual false proofs sit. What is new is therefore not the observation that a snapshot goes stale, but the measurement of when staleness produces a *false proof* rather than a miss, the separation of that mechanism from an unsound oracle, and the fact that the residual survives the strongest tester-side bookkeeping.

Action. Section V-A (Table 12, p. 15); Section VI-A; the related-work claim restated in Section IX.

2.2 Scope of claims: two relations of one family

Concern. Only 2 of 76 relations were studied and only 2 of 11 authorization relations fired on Gitea; the title and abstract should be narrowed or the evaluation extended.

Response. The title, the running head, the PDF title and the abstract are narrowed to the two reachability-gated relations in MST-wi, and the abstract opens by naming them as two relations of that framework. The native trigger range is stated where the run is reported rather than in the abstract, which is kept to the IEEE single-paragraph, 250-word limit: Section VII-C and Table 24 (p. 25) record that of the 11 catalog authorization relations evaluated against Gitea, 10 ran and 2 alarmed, both of them reachability-gated (OTG_AUTHZ_002, OTG_AUTHZ_002c). We did not extend the evaluation to other relation families; Section VIII names this as the paper's single most important limitation and says what raising it would require—relations gated otherwise, which is a different experiment.

Action. Title, running head, abstract, Section VIII.

2.3 Proposition 2

Concern. It is close to true by definition; separate what is empirical from what is definitional.

Response. The same split as under Reviewer 1, comment 5, restated here so this comment stands on its own. The algebraic absorption is a lemma and is labelled definitional: a verdict that is a function of an oracle answer and an ordinary request cannot outperform the direct consumer of those same inputs. The claim that *these two* relations satisfy the lemma's premise is a separate proposition whose premise is checked against the records: their alarms reduce to $y \wedge \neg m$ on the domain studied, against $D = y \wedge \neg o$, and the truth table (Table 19, p. 20) makes the functional representation explicit. The lemma's second premise—that the model is O-determined—is not claimed and fails on the stale cells, so the paper does not present the relations as informationally redundant in general.

Action. Section VI-B, Table 19 (p. 20).

2.4 Detection side: no real system was vulnerable

Concern. Either add a real vulnerable case or remove the claim that the metamorphic step adds nothing for detection.

Response. Both halves were done. A real vulnerable/fixed pair was added (Section V-E, Table 18, p. 18): a publicly fixed Gitea defect, one true positive on the vulnerable build, no claim on the fixed build, and twelve control checks (ten expected responses plus two recovery checks) passing under a fail-closed validator that recomputes the effect from the owner's re-read. And the claim was narrowed: the manuscript no longer says the metamorphic step adds nothing *for detection*; what it supports is that the step adds no adjudication information where a readable, sound oracle exists (Lemma 1 and Proposition 2), and that the relations' recall on real defects is unevaluated—which Section X states as the boundary of the evidence.

Action. Section V-E and Table 18; Section VI-B; Section X.

2.5 The 84.62% figure

Concern. It assumes two inputs per case and is only illustrative; keep it out of the abstract and do not present it as quantitative support.

Response. The figure is absent from the abstract and has now been removed from the body as well; it appears nowhere in the manuscript and is not used as quantitative support for anything. The denominator argument is made in parameterized form instead (Section IV-E).

Action. Section IV-E; verified absent from the compiled manuscript.

2.6 Constructed ground truth and the reported rates

Concern. Discuss how far the false-proof rates reflect the scenario design, such as the per-cell multipliers, rather than the technique.

Response. The manuscript states in several places that the channel proportions are topology design parameters and not field prevalence, that the eight transitions are a designed set and not a sample of deployment changes, and that the out-of-band share quoted on the real system is a property of the constructed topology. The design dependence is also made inspectable rather than asserted: Table 5 gives the per-block record counts behind the 312/264 partition, Table 23 gives the per-cell census, and the matched-pair attribution (Table 2) shows exactly which cells carry each effect—the false-proof saving falls on one scenario, the legitimate share created through the framework's own facility, while the out-of-band scenario agrees with the reference. The reported rates are therefore presented as properties of the construction, not as deployment rates.

Action. Sections V-B, VI-A and VIII; Tables 2, 5 and 23.

What remains. We did not recompute the constructed rates under equal per-cell weights in parallel with the original weights; the sensitivity to the weighting is described qualitatively rather than tabulated.

3 Answers to the additional questions

Reviewer 1 and Reviewer 2. Both evaluation forms ask the same itemized questions (contribution, technical soundness, comprehensiveness, references). Rather than restate a self-assessment against each, we point to where the revision addresses the substance: contribution and positioning in Section IX and Table 22; the separation of the definitional from the empirical in Section VI; scope, boundaries and the named gaps in Section VIII and the partial-response list above; and the revised, traceable bibliography. The judgement on each item belongs to the reviewers and the editor.

4 What this revision does not claim

For the Associate Editor's convenience, this section records the three items that earlier drafts of this letter listed as met only in part. All three have now been addressed by experiment, and the table states what was run and what each result does *not* establish. No row records a requested experiment that was not run. Several items that earlier drafts listed here are no longer listed, because the missing element named there was our own proposed extension rather than something the reviewer asked for: R1.12 asked for the derivation to be extended to unequal and endogenous counts, which the conditional derivation now does, and no generative-model experiment was part of that request; R2.6 asked for a discussion of how constructed rates depend on the design, which the manuscript states, and no equal-weight reanalysis was mandated by its wording; R1.1 asked for a structured, qualitative known/new comparison, which the response above and Section IX provide, and did not ask for a bibliometric or quantitative survey; R1.14 asked for reproducible materials, versions and commands, which the package provides, and did not require re-execution on a second machine—the same-host scope of the regeneration is stated as an evidence boundary in the R1.14 response itself; and R2.4 offered two alternatives, of which the manuscript has taken the second (the claim of no detection gain from metamorphic testing is withdrawn), so it is answered by narrowing rather than partly met.

Item	What was run	What the result does not establish
R1.4	An admission protocol frozen with its digest before the new runs: four defect classes, evidence levels L0–L3, an ordered *admit*/*reject*/*unknown* rule, claim licensing and change control; applied to the four archived products (all *reject*, L1) and to the controlled target (*reject*, L2, source-level)	Independence for the three production products: their evidence stops at the server boundary, so no promotion is claimed there and their results remain diagnostic readings
R1.7	The probe-pair comparison plus a matched total-request ceiling (2 and 3 requests per cell) with the same accounts and credentials, a declared allocation of the one extra observation each method may spend, and cost, detection, false-proof and abstention counts side by side	A detection advantage: at the matched ceiling the strengthened baseline reaches 14 of 15 violations with 4 false proofs against our 10 with none and 17 abstentions; and the curve has two points, not a sweep
R1.9	Four defect classes (read, modify, inheritance, escalation), 9 independently switchable instances, the same crawl/introspection/adjudication code, per-class recall and false alarms, and a leave-one-out run per class	Population evidence: one emulator and four mechanisms, not four discoveries in production systems; the gate is blind to inheritance and escalation by construction and was not retuned to catch them

The residual in the third column is scope, not missing work, and each limit is stated in the manuscript where the corresponding number appears. Where the rule refuses promotion, the number is still reported—as a diagnostic reading, not as a confirmed violation.

5 Files in this resubmission

1. This response to reviewers.
2. The revised manuscript with all changes highlighted.
3. A clean copy of the revised manuscript, as PDF and as the LaTeX source package (93 files), which compiles in an empty directory. The numbers themselves are reproduced by the full repository—raw records, generators and verification scripts—which is archived separately; the 93-file package contains the typesetting sources, not the raw records.